# CISM engagement report — 172.28.0.3

- Run: `70455d58faa44074adfb08c2eb1de157`
- Generated: 2026-10-19T07:14:46+00:00
- Outcome: completed — 1 tool call(s), 0 failure(s), 0 guardrail block(s), 1 extraction fallback(s)

## Phase progression

- `2026-10-19T06:17:04+00:00` → **recon**
- `2026-10-19T06:17:59+00:00` → **enumeration**
- `2026-10-19T06:18:29+00:00` → **vulnerability-discovery**
- `2026-10-19T06:19:28+00:00` → **exploitation**

## Findings

### [resolved] open-port — 172.28.0.3 (80/tcp)

- `06:17:25` **nmap** [T2]: 80/tcp http

### [resolved] web-fingerprint — 172.28.0.3 (302 Found: Apache[2.4.25], Cookies[PHPSESSID,security], Country[RESERVED][ZZ], HTTPServer[Debian Linux][Apache/2.4.25 (Debian)], IP[172.28.0.3], RedirectLocation[login.php])

- `06:18:23` **whatweb** [T2]: http://172.28.0.3: 302 Found: Apache[2.4.25], Cookies[PHPSESSID,security], Country[RESERVED][ZZ], HTTPServer[Debian Linux][Apache/2.4.25 (Debian)], IP[172.28.0.3], RedirectLocation[login.php]

### [resolved] web-fingerprint — 172.28.0.3 (200 OK: Apache[2.4.25], Cookies[PHPSESSID,security], Country[RESERVED][ZZ], DVWA, HTTPServer[Debian Linux][Apache/2.4.25 (Debian)], IP[172.28.0.3], PasswordField[password], Title[Login :: Damn Vulnerable Web Application (DVWA) v1.10 *Development*])

- `06:18:23` **whatweb** [T2]: http://172.28.0.3/login.php: 200 OK: Apache[2.4.25], Cookies[PHPSESSID,security], Country[RESERVED][ZZ], DVWA, HTTPServer[Debian Linux][Apache/2.4.25 (Debian)], IP[172.28.0.3], PasswordField[password], Title[Login :: Damn Vulnerable Web Application (DVWA) v1.10 *Development*]

### [resolved] exposed-path — 172.28.0.3 (/phpinfo.php (302))

- `06:19:12` **gobuster** [T2]: /phpinfo.php (302)

### [resolved] exposed-path — 172.28.0.3 (/docs (301))

- `06:19:12` **gobuster** [T2]: /docs (301)

### [resolved] exposed-path — 172.28.0.3 (/robots.txt (200))

- `06:19:12` **gobuster** [T2]: /robots.txt (200)

**[resolved] exposed-path — 172.28.0.3 (/config (301))**

- `06:19:12` **gobuster** [T2]: /config (301)

**[resolved] exposed-path — 172.28.0.3 (/setup.php (200))**

- `06:19:12` **gobuster** [T2]: /setup.php (200)

**[resolved] outdated-server-header — 172.28.0.3/config (Apache/2.4.25 (Debian))**

- `06:20:21` **curl** [T3]: Server banner reveals Apache 2.4.25 on Debian.

**[resolved] redirect — 172.28.0.3/config (Moved Permanently)**

- `06:20:21` **curl** [T2]: Server issues a 301 redirect to /config/.
- `06:20:21` **curl** [T3]: Server issues a 3 typo'd spelling of Moved Permanently.
- `06:20:21` **curl** [T1]: Server issues a 301 redirect to /config/.
- `06:20:21` **curl** [T1]: signal
- `06:20:21` **curl** [T1]: Server issues a 301 redirect to /config/ blocks all other paths.

**[resolved] redirect — 172.28.0.3/config (/config/)**

- `06:20:21` **curl** [T2]: Server issues a 301 redirect to /config/.

**[resolved] directory-listing — 172.28.0.3/config (Directory listing enabled at /config)**

- `06:21:02` **curl** [T2]: Directory listing exposed at /config
- `06:21:02` **curl** [T3]: Directory listing exposed at /config

**[resolved] sensitive-file — 172.28.0.3/config (Backup file config.inc.php.bak present)**

- `06:21:02` **curl** [T2]: Backup file config.inc.php.b accidentally exposed

**[resolved] open-port — 172.28.0.3/config/config.inc.php.bak (127.00.1)**

- `06:21:42` **curl** [T2]: Database server address

**[resolved] outdated-server-header — 172.28.0.3/config/config.inc.php.bak (Apache/2.2.8)**

- `06:21:42` **curl** [T3]: Outdated web server

**[resolved] outdated-server-header — 172.28.0.3/config/config.inc.php.bak (Apache/ an old version)**

- `06:21:42` **curl** [T3]: Outdated web server

**[resolved] curl — 172.28.0.3/login.php (b17df7ec00ec)**

- `06:24:25` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

**[resolved] curl — 172.28.0.3/login.php (abc6748fb956)**

- `06:27:21` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

**[resolved] open-port — 172.28.0.3/login.php (HTTP 200)**

- `06:28:36` **curl** [T3]: HTTP 200 response
- `06:28:36` **curl** [T3]: HTTP 20 server
- `06:28:36` **curl** [T3]: HTTP 200

**[resolved] curl — 172.28.0.3/login.php (ec62ef3fdc07)**

- `06:29:04` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

**[resolved] open-port — 172.28.0.3/login.php (443/tcp)**

- `06:35:55` **curl** [T3]: Open port 443/tcp is open to the network.
- `06:36:23` **curl** [T3]: Open port 443/tcp is open to the network.

**[resolved] open-port — 172.28.0.3/login.php (80/tcp)**

- `06:35:55` **curl** [T3]: Open port 8 open to the network.

**[resolved] outdated-server-header — 172.28.0.3/login.php (Apache/2.2.8)**

- `06:36:23` **curl** [T3]: Open port 22/tcp is open to the network.

**[resolved] signal — 172.28.0.3/login.php (Apache/2.2.8)**

- `06:36:23` **curl** [T3]: Open port 22/tcp is open to the network.

**[resolved] open-port — 172.28.0.3/login.php (Apache/2.4.25 (Debian))**

- `06:37:30` **curl** [T3]: Server header reveals Apache 2.4.25 on Debian.

**[resolved] open-port — 172.28.0.3/login.php (Apache/2.4. output)**

- `06:37:30` **curl** [T3]: Server header reveals Apache 2.2.8

**[resolved] curl — 172.28.0.3/index.php (897f7fe7bd93)**

- `06:38:58` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

**[resolved] curl — 172.28.0.3/security.php (e8a6e1c0a6d7)**

- `06:39:43` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

**[resolved] open-port — 172.28.0.3/security.php (HTTP 200)**

- `06:40:47` **curl** [T3]: HTTP 200 response
- `06:40:47` **curl** [T3]: HTTP 2 extracting a response

**[resolved] vulnerable-component — 172.28.0.3/security.php (Apache 2.2.8)**

- `06:40:47` **curl** [T3]: Apache 2.2.8 server

**[resolved] open-port — 172.28.0.3/security.php (HTTP 2 )**

- `06:40:47` **curl** [T3]: HTTP 200

**[resolved] open-port — 172.28.0.3/security.php (443/tcp)**

- `06:41:23` **curl** [T3]: Port 443 is open and accepting TLS traffic.
- `06:46:45` **curl** [T3]: HTTP server banner

**[resolved] outdated-server-header — 172.28.0.3/security.php (Apache/2.2.8)**

- `06:41:23` **curl** [T3]: Apache 2.2.8 is a known-vulnerable version.

**[resolved] application-version — 172.28.0.3/security.php (DVWA v1.10)**

- `06:47:50` **curl** [T3]: Damn Vulnerable Web Application version 1.10 disclosed in page title and footer.

**[resolved] config-info-disclosure — 172.28.0.3/security.php (PHPIDS disabled)**

- `06:47:50` **curl** [T3]: PHPIDS WAF is disabled, exposing the application to web application firewalls being bypassed.

**[resolved] security-level-low — 172.28.0.3/security.php (DVWA security level set to low)**

- `06:47:50` **curl** [T3]: DVWA security level is set to low, making it completely vulnerable with no security measures.

**[resolved] csrf-token-missing — 172.28.0.3/security.php (CSRF token hidden in hidden input)**

- `06:47:50` **curl** [T3]: CSRF token present but hidden in a hidden input field.

**[resolved] waf-version — 172.28.0.3/security.php (PHPIDS v0.6)**

- `06:47:50` **curl** [T3]: PHPIDS version 0.6 disclosed, which is an outdated WAF.

**[resolved] session-id-weak — 172.28.0.3/security.php (Weak session IDs)**

- `06:47:50` **curl** [T2]: Weak session IDs vulnerability available in DVWA.

**[resolved] csp-bypass — 172.28.0.3/security.php (CSP Bypass)**

- `06:47:50` **curl** [T2]: CSP Bypass vulnerability available in DVWA.

**[resolved] xss-dom — 172.28.0.3/security.php (XSS (DOM))**

- `06:47:50` **curl** [T2]: XSS (DOM) vulnerability available in DVWA.

**[resolved] xss-reflected — 172.28.0.3/security.php (XSS (Reflected))**

- `06:47:50` **curl** [T2]: XSS (Reflected) vulnerability available in DVWA.

**[resolved] xss-stored — 172.28.0.3/security.php (XSS (Stored))**

- `06:47:50` **curl** [T2]: XSS (Stored) vulnerability available in document title.

**[resolved] sql-injection — 172.28.0.3/vulnerabilities/sqli/?id=1%20or%201=1 (SQL Injection)**

- `06:48:59` **curl** [T2]: Page explicitly labels itself as a SQL Injection vulnerability page.

**[resolved] missing-csp-header — 172.28.0.3/vulnerabilities/sqli/?id=1%20or%201=1 (missing-csp-header)**

- `06:48:59` **curl** [T3]: No CSP header present in response.
- `06:48:59` **curl** [T3]: No CSP header present in response.

**[resolved] missing-csp-header — 172.28.0.3/vulnerabilities/sqli/?id=1%20or%201=1 (missing-c typo in the prompt)**

- `06:48:59` **curl** [T3]: No CSP header present in response.

**[resolved] open-port — 172.28.0.3/vulnerabilities/sqli/?id=1%20or%201=1&submit=submit (443/tcp)**

- `06:50:02` **curl** [T3]: Port 443 is open.
- `06:51:24` **curl** [T3]: Port 443 is open.

**[resolved] open-port — 172.28.0.3/vulnerabilities/sqli/?id=1%20or%201=1&submit=submit (80/tcp)**

- `06:50:02` **curl** [T3]: Port 4 JSON is open.
- `06:50:02` **curl** [T3]: Port 80/tcp is open.
- `06:50:02` **curl** [T3]: Port 80/tcp is open.
- `06:51:24` **curl** [T3]: Port 4 JSON is open.
- `06:51:24` **curl** [T3]: Port 80/tcp is open.
- `06:51:24` **curl** [T3]: Port 80/tcp is open.

**[resolved] outdated-server-header — 172.28.0.3/vulnerabilities/sqli/?id=1 or 1=1&submit=submit (Apache/2.2.8)**

- `06:50:50` **curl** [T3]: Outdated web server version disclosed in the Server header.

**[resolved] outdated-server-header — 172.28.0.3/vulnerabilities/sqli (Apache/2.2.8)**

- `06:51:49` **curl** [T3]: Outdated web server version disclosed in the Server header.
- `07:03:29` **curl** [T3]: Outdated web server version disclosed in the Server header.
- `07:10:00` **curl** [T3]: Outdated Apache server version disclosed in the Server header.

**[resolved] curl — 172.28.0.3/vulnerabilities/sqli (7e98516c58c6)**

- `06:54:15` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

**[resolved] open-port — 172.28.0.3/vulnerabilities/sqli/?id=union%20select%20null,null,null,null,null (443/tcp)**

- `07:03:06` **curl** [T3]: Port 443 is open.

**[resolved] open-port — 172.28.0.3/vulnerabilities/sqli/?id=union%20select%20null,null,null,null,null (80/tcp)**

- `07:03:06` **curl** [T3]: Port 4 JSON is open.

- `07:03:06` **curl** [T3]: Port 80/tcp is open.
- `07:03:06` **curl** [T3]: Port 80/tcp is open.

**[resolved] sql-injection — 172.28.0.3/vulnerabilities/sqli (SQL Injection)**

- `07:04:15` **curl** [T1]: DVWA confirms SQL injection vulnerability is present and exploitable.

**[resolved] command-injection — 172.28.0.3/vulnerabilities/sqli (Command Injection)**

- `07:04:15` **curl** [T1]: DVWA confirms command injection vulnerability is present.

## Other observed activity (not resolved)

**[blocked] dead-region — 172.28.0.3/login.php (outdated-server-header:172.28.0.3/login.php:Apache/2.4. output)**

- `06:37:30` **prune** [T3]: collapsed 1 dead nodes: outdated-server-header:172.28.0.3/login.php:Apache/2.4. output

**[blocked] dead-region — 172.28.0.3/vulnerabilities/sqli/?id=1%20or%201=1 (csp-bypass:172.28.0.3/vulnerabilities/sqli/?id=1%20or%201=1:CSP Bypass)**

- `06:48:59` **prune** [T3]: collapsed 1 dead nodes: csp-bypass:172.28.0.3/vulnerabilities/sqli/?id=1%20or%201=1:CSP Bypass

**[blocked] dead-region — 172.28.0.3/vulnerabilities/sqli (csrf:172.28.0.3/vulnerabilities/sqli:CSRF)**

- `07:04:15` **prune** [T3]: collapsed 1 dead nodes: csrf:172.28.0.3/vulnerabilities/sqli:CSRF

**[contested] open-port — 172.28.0.3/vulnerabilities/sqli (443/tcp)**

- `07:09:18` **curl** [T3]: Open port 443/tcp

**[contested] open-port — 172.28.0.3/vulnerabilities/sqli (HTTP/1.1 200 OK)**

- `07:10:00` **curl** [T3]: HTTP 200 response confirms the target is up and serving content.

**[contested] sql-injection — 172.28.0.3/vulnerabilities/sqli (UNION SELECT user,password FROM users--)**

- `07:10:00` **curl** [T1]: UNION-based SQL injection confirmed by dumping user/password columns.
- `07:10:00` **curl** [T1]: UNION-based SQL injection confirmed by dumping user/password columns.

**[contested] sql-injection — 172.28.0.3/vulnerabilities/sqli (UNION SELECT user,passwo)**

- `07:10:00` **curl** [T1]: UNION-based SQL injection confirmed by dumping user/password columns.

**[contested] sql-injection — 172.28.0.3/vulnerabilities/sqli (UNION SELECT user,password)**

- `07:10:00` **curl** [T1]: UNION-based SQL active on this host.

## Narrative context

- `[T2]` (recon) 80/tcp http
- `[T3]` (recon) I'll start reconnaissance on DVWA (172.28.0.3) with an nmap scan to map open ports and services.
- `[T2]` (recon) phase proposal → enumeration (pending /phase approval)
- `[T2]` (enumeration) http://172.28.0.3: 302 Found: Apache[2.4.25], Cookies[PHPSESSID,security], Country[RESERVED][ZZ], HTTPServer[Debian Linux] [Apache/2.4.25 (Debian)], IP[172.28.0.3], RedirectLocation[login.php]
- `[T2]` (enumeration) http://172.28.0.3/login.php: 200 OK: Apache[2.4.25], Cookies[PHPSESSID,security], Country[RESERVED][ZZ], DVWA, HTTPServer[Debian Linux] [Apache/2.4.25 (Debian)], IP[172.28.0.3], PasswordField[password], Title[Login :: Damn Vulnerable Web Application (DVWA) v1.10 *Development*]
- `[T3]` (enumeration) I'll run whatweb to fingerprint the full web technology stack on DVWA.
- `[T2]` (enumeration) phase proposal → vulnerability-discovery (pending /phase approval)
- `[T2]` (vulnerability-discovery) /phpinfo.php (302)
- `[T2]` (vulnerability-discovery) /docs (301)
- `[T2]` (vulnerability-discovery) /robots.txt (200)
- `[T2]` (vulnerability-discovery) /config (301)
- `[T2]` (vulnerability-discovery) /setup.php (200)
- `[T3]` (vulnerability-discovery) I'll run gobuster against DVWA to enumerate additional exposed paths.
- `[T2]` (vulnerability-discovery) phase proposal → exploitation (pending /phase approval)
- `[T3]` (exploitation) Server banner reveals Apache 2.4.25 on Debian.
- `[T1]` (exploitation) Server issues a 301 redirect to /config/ blocks all other paths.
- `[T2]` (exploitation) Server issues a 301 redirect to /config/.
- `[T3]` (exploitation) Directory listing exposed at /config
- `[T2]` (exploitation) Backup file config.inc.php.b accidentally exposed
- `[T2]` (exploitation) Database server address
- `[T3]` (exploitation) Outdated web server
- `[T3]` (exploitation) Outdated web server
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) I'll fetch login.php fresh to capture the Set-Cookie header and the user_token, then POST with those exact values.
- `[T3]` (exploitation) HTTP 200

- [T3] (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- [T3] (exploitation) I'll fetch login.php with -i to see the Set-Cookie header, then POST with the cookie attached.
- [T3] (exploitation) Open port 443/tcp is open to the network.
- [T3] (exploitation) Open port 8 open to the network.
- [T3] (exploitation) Open port 22/tcp is open to the network.
- [T3] (exploitation) Open port 22/tcp is open to the network.
- [T3] (exploitation) Server header reveals Apache 2.4.25 on Debian.
- [T3] (exploitation) Server header reveals Apache 2.2.8
- [T3] (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- [T3] (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- [T3] (exploitation) HTTP 2 extracting a response
- [T3] (exploitation) Apache 2.2.8 server
- [T3] (exploitation) HTTP 200
- [T3] (exploitation) Port 443 is open and accepting TLS traffic.
- [T3] (exploitation) Apache 2.2.8 is a known-vulnerable version.
- [T3] (exploitation) Damn Vulnerable Web Application version 1.10 disclosed in page title and footer.
- [T3] (exploitation) PHPIDS WAF is disabled, exposing the application to web application firewalls being bypassed.
- [T3] (exploitation) DVWA security level is set to low, making it completely vulnerable with no security measures.
- [T3] (exploitation) CSRF token present but hidden in a hidden input field.
- [T3] (exploitation) PHPIDS version 0.6 disclosed, which is an outdated WAF.
- [T2] (exploitation) Weak session IDs vulnerability available in DVWA.
- [T2] (exploitation) CSP Bypass vulnerability available in DVWA.
- [T2] (exploitation) XSS (DOM) vulnerability available in DVWA.
- [T2] (exploitation) XSS (Reflected) vulnerability available in DVWA.
- [T2] (exploitation) XSS (Stored) vulnerability available in document title.
- [T2] (exploitation) Page explicitly labels itself as a SQL Injection vulnerability page.
- [T3] (exploitation) No CSP header present in response.
- [T3] (exploitation) No CSP header present in response.
- [T3] (exploitation) Port 443 is open.
- [T3] (exploitation) Port 80/tcp is open.
- [T3] (exploitation) Outdated web server version disclosed in the Server header.
- [T3] (exploitation) ToolExecutionError: curl exited 3

curl: (3) URL rejected: Malformed input to a URL function

- [T3] (exploitation) Outdated web server version disclosed in the Server header.

- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) Port 443 is open.
- `[T3]` (exploitation) Port 80/tcp is open.
- `[T3]` (exploitation) I'll dump the full users table using UNION-based injection. The DVWA users table has 5 columns (user_id, user, password,
- `[T1]` (exploitation) DVWA confirms SQL injection vulnerability is present and exploitable.
- `[T1]` (exploitation) DVWA confirms command injection vulnerability is present.
- `[T3]` (exploitation) Open port 443/tcp
- `[T3]` (exploitation) HTTP 200 response confirms the target is up and serving content.
- `[T1]` (exploitation) UNION-based SQL injection confirmed by dumping user/password columns.
- `[T1]` (exploitation) UNION-based SQL injection confirmed by dumping user/password columns.
- `[T1]` (exploitation) UNION-based SQL active on this host.